Technischer Sicherheitsprüfbericht

Zwischenstand einer autorisierten, passiven Web-Sicherheitsprüfung

Ziel: Karolinen-Gymnasium Rosenheim – öffentliche Webpräsenz und separat betrachtete Portale
Stand: 26. Oktober 2026
Status: Zwischenbericht – technische Verifikation nicht abgeschlossen

Management Summary

Im Rahmen der bisherigen Arbeiten wurden öffentlich erreichbare Seiten der Schulwebsite manuell aufgerufen und der dabei beobachtete HTTP-Verkehr mit OWASP ZAP 2.17.0 im passiven Modus ausgewertet. Ergänzend wurden ausgewählte Response-Header in den Browser-Entwicklertools betrachtet. Der Testansatz war bewusst nicht-invasiv: Es wurden keine aktiven Scans, Exploit-Versuche, Belastungstests oder Tests an geschützten Konten durchgeführt.

Die passive Analyse lieferte mehrere technisch relevante Prüfhinweise. Dazu zählen Meldungen zu einer fehlenden Content Security Policy, fehlendem HTTP Strict Transport Security in untersuchten Antworten, einem fehlenden Anti-Clickjacking-Header sowie die Erkennung von jQuery 2.2.4. Diese Ergebnisse bilden eine priorisierbare Grundlage für eine Betreiberprüfung. Sie sind jedoch nicht mit bestätigten, ausnutzbaren Sicherheitslücken gleichzusetzen.

Die Website wurde über HTTPS erreicht; nach Angaben des Nutzers wird HTTP auf HTTPS umgeleitet. In mindestens einer untersuchten Antwort war `X-Content-Type-Options: nosniff` gesetzt. Die Unterschiede zwischen den beobachteten Antworten zeigen, warum Header-Befunde anhand konkreter URLs und Response-Typen verifiziert werden müssen, bevor systemweite Aussagen getroffen werden.

1. Prüfauftrag, Umfang und Annahmen

Der Nutzer gibt an, über eine schriftliche Genehmigung für die genannten Ziele zu verfügen. Diese Genehmigung wurde im Rahmen dieses Berichts nicht unabhängig geprüft. Die beiden Portale werden auf separaten Domains betrieben und sind deshalb als eigenständige Systeme zu behandeln. Aussagen über die Schulwebsite dürfen nicht automatisch auf die Portale übertragen werden.

System	Durchgeführte Betrachtung
Öffentliche Schulwebsite karolinen-gymnasium-rosenheim.de	Normale Seitenaufrufe, ausgewählte Response-Header in DevTools und passive Analyse mit ZAP.
Schülerportal schueler.schule-infoportal.de	Öffentliche Login-Seite, PWA-Manifest und Service-Worker-Status beobachtet; keine Anmeldung oder Prüfung geschützter Funktionen.
Elternportal karogyro.eltern-portal.org	Öffentliche Login-Seite betrachtet; keine Anmeldung oder Prüfung geschützter Funktionen.

Ausdrücklich nicht Bestandteil der bisherigen Prüfung waren aktive Schwachstellenscans, das Ausnutzen von Schwachstellen, Umgehungen von Authentifizierung oder Berechtigungen, das Testen fremder Konten, Lasttests und die Verarbeitung realer Schüler- oder Elterndaten. Der Zwischenstand erlaubt daher keine Aussage über die vollständige Sicherheit der Systeme.

2. Vorgehensweise und technische Nachvollziehbarkeit

Werkzeugbasis: OWASP ZAP 2.17.0 unter Windows mit integriertem Browser. Der Nutzer öffnete die Schulwebsite auf normalem Weg; ZAP wertete die aufgezeichneten HTTP-Nachrichten passiv aus. Passive Scanner analysieren Requests und Responses, ohne gezielt Payloads einzuschleusen oder die Anwendung durch aktive Angriffstests zu prüfen.

Für eine belastbare Nachprüfung sollten pro Alert mindestens folgende Angaben erhalten bleiben: betroffene URL bzw. Ressource, HTTP-Status, Alert-Titel, ZAP-Risikostufe, Confidence, beobachteter Header bzw. Bibliotheksname und Datum der Prüfung. Sensible Cookie-Werte, Tokens und Zugangsdaten gehören nicht in den Bericht.

Die von ZAP angezeigten Risikostufen und Confidence-Werte werden nachfolgend als Werkzeugbewertungen ausgewiesen. Sie ersetzen keine manuelle Validierung und keine Prüfung der tatsächlichen Ausnutzbarkeit.

3. Technische Befunde

F-01 | Content Security Policy (CSP) Header Not Set

Werkzeugbewertung: Medium; Confidence: High (laut ZAP).
Beobachtung: ZAP meldete für die untersuchte Startseitenantwort, dass kein CSP-Header erkannt wurde. Eine Content Security Policy kann die zulässigen Quellen für Skripte, Styles, Bilder und weitere Ressourcen begrenzen und damit eine zusätzliche Schutzschicht gegen bestimmte clientseitige Angriffe bilden.
Einordnung: Fehlende CSP ist zunächst eine Härtungs- bzw. Konfigurationslücke. Daraus allein folgt nicht, dass Cross-Site Scripting möglich ist oder erfolgreich ausgenutzt werden kann.
Empfehlung: Der Betreiber sollte eine auf die Anwendung abgestimmte Policy entwickeln, zunächst im Report-Only-Modus auswerten und anschließend kontrolliert durchsetzen. Inline-Skripte und externe Ressourcen sollten nur berücksichtigt werden, soweit sie tatsächlich benötigt werden.

F-02 | Strict-Transport-Security Header Not Set (Systemic)

Werkzeugbewertung: Low; Confidence: High (laut ZAP).
Beobachtung: ZAP meldete fehlendes HSTS in mehreren beobachteten Antworten. HTTPS war aktiv; laut Nutzer leitet HTTP auf HTTPS um.
Einordnung: Die Weiterleitung ist eine positive Beobachtung, ersetzt aber nicht die HSTS-Anweisung, die Browser nach Erhalt einer gültigen Richtlinie zu künftigen HTTPS-Verbindungen anhält. Die genaue Abdeckung muss für relevante HTTPS-Antworten geprüft werden.
Empfehlung: HSTS für die vorgesehenen Hostnamen konfigurieren und Laufzeit sowie Subdomain-Abdeckung bewusst festlegen. Optionen wie `includeSubDomains` sollten nur verwendet werden, wenn alle betroffenen Subdomains dauerhaft HTTPS unterstützen.

F-03 | Vulnerable JS Library – jQuery 2.2.4

Werkzeugbewertung: Medium; Confidence: Medium (laut ZAP).
Beobachtung: ZAP/Retire.js erkannte jQuery 2.2.4 und verwies auf CVE-2020-11022 sowie CVE-2020-11023. Die erkannte Version ist veraltet und liegt vor Versionen, in denen diese Probleme behoben wurden.
Einordnung: Die Bibliothekserkennung ist ein relevanter Hinweis auf veraltete clientseitige Abhängigkeiten. Ob eine betroffene Funktion im konkreten Anwendungskontext mit nicht vertrauenswürdigen Inhalten verwendet wird, wurde nicht geprüft. Eine erfolgreiche Ausnutzung wurde nicht demonstriert.
Empfehlung: Die Verantwortlichen sollten die eingebundene Version und ihre Nutzung verifizieren, Abhängigkeiten aktualisieren und die Funktionalität nach einem Update testen. Ein Update sollte kontrolliert erfolgen, damit keine legitimen Website-Funktionen beschädigt werden.

F-04 | Missing Anti-clickjacking Header

Werkzeugbewertung: Medium; Confidence: Medium (laut ZAP).
Beobachtung: In der untersuchten Antwort wurde kein `X-Frame-Options`-Header erkannt. Für diesen konkreten Befund wurde eine mögliche CSP-Direktive `frame-ancestors` nicht separat verifiziert.
Einordnung: Der Alert deutet auf eine mögliche fehlende Einbettungsbeschränkung hin. Er beweist nicht, dass ein erfolgreicher Clickjacking-Angriff auf eine relevante Funktion möglich ist.
Empfehlung: Der Betreiber sollte festlegen, ob und durch welche Ursprünge die Website eingebettet werden darf, und diese Regel mit `frame-ancestors` und/oder `X-Frame-Options` umsetzen.

4. Weitere erkannte Alert-Kategorien

Die folgenden Kategorien waren in ZAP sichtbar, wurden aber noch nicht anhand ihrer vollständigen Detailinformationen verifiziert. Sie werden deshalb ausdrücklich als offene Prüfhinweise und nicht als bestätigte Schwachstellen geführt:

- Cross-Domain Misconfiguration (2)
- X-Content-Type-Options Header Missing
- Timestamp Disclosure – Unix (2)
- Information Disclosure – Suspicious Comments (7)
- Modern Web Application
- Re-examine Cache-control Directives (3)

Besonders der Alert zu fehlendem X-Content-Type-Options sollte mit den zuvor beobachteten Antworten abgeglichen werden: In mindestens einer Antwort war `nosniff` vorhanden. Unterschiedliche Ressourcen, Weiterleitungen oder Antworttypen können unterschiedliche Header besitzen. Ohne Abgleich der konkreten Requests ist daraus kein globaler Widerspruch abzuleiten.

5. Zusätzliche Beobachtungen ohne bestätigten Sicherheitsmangel

• HTTPS und Weiterleitung: Die Website wurde über HTTPS geladen; laut Nutzer wird HTTP auf HTTPS umgeleitet. Dies ist eine positive Basiskontrolle, aber kein vollständiger Nachweis einer sicheren TLS-Konfiguration.
• Cookie-Beobachtung: Ein Cookie namens `in2cookiemodal-selection` war sichtbar. Funktion und Attribute konnten nicht zuverlässig abschließend verifiziert werden; deshalb wird daraus kein eigenständiger Befund abgeleitet.
• Schülerportal-PWA: Das Manifest enthielt typische PWA-Angaben wie Name, Icons und `display: standalone`. Ein Service Worker wurde als aktiviert angezeigt. Diese Merkmale sind für eine PWA erwartbar und stellen für sich keinen Sicherheitsmangel dar.
• HTTP 304: Eine einzelne Antwort mit Status 304 reicht nicht aus, um die Sicherheitsheader-Konfiguration aller Antworten eines Systems zu beurteilen.
• Server-/TYPO3-Header: Plattformhinweise wurden beobachtet. Sie sind allein kein Schwachstellennachweis; unnötige Versionsdetails sollten nur dann als Informationsrisiko bewertet werden, wenn konkrete sensible Informationen offengelegt werden.

6. Priorisierte Maßnahmen

Priorität 1 – Clientseitige Abhängigkeit: jQuery 2.2.4 und die genannten CVEs durch den Betreiber verifizieren; falls die Bibliothek benötigt wird, eine aktuelle unterstützte Version nach Kompatibilitätstests einsetzen.
Priorität 2 – Sicherheitsheader: CSP, HSTS und Einbettungsschutz auf relevanten Antworten prüfen und abgestimmt konfigurieren.
Priorität 3 – Inkonsistenzen aufklären: betroffene URLs und Antworttypen für den nosniff-Alert vergleichen; Cross-Domain- und Cache-Control-Hinweise anhand der Details prüfen.
Priorität 4 – Verifikation nach Änderungen: nach freigegebenen Korrekturen erneut passive Requests erfassen und die konkreten Response-Header dokumentieren.

7. Geplante nächste Schritte

1. Alert „Cross-Domain Misconfiguration (2)“ in ZAP öffnen und die betroffene URL, Risikostufe, Confidence und Beschreibung notieren.
2. „X-Content-Type-Options Header Missing“ auf konkrete Ressource und Antworttyp prüfen und mit der bereits beobachteten Antwort vergleichen, in der `nosniff` gesetzt war.
3. Cache-Control-Hinweise anhand der sichtbaren Direktiven und des betroffenen Ressourcentyps einordnen.
4. Ergebnisse zusammenführen und den Abschlussbericht erst nach ausdrücklicher Freigabe des Nutzers erstellen.

8. Fazit und Einschränkungen

Die bisherige passive Prüfung hat mehrere sinnvolle Ansatzpunkte für eine technische Härtung sichtbar gemacht. Besonders zu priorisieren sind die erkannte jQuery-Version sowie die von ZAP gemeldeten Header-Konfigurationen. Die Befunde sollten durch die verantwortlichen Betreiber anhand der konkreten Antworten überprüft werden. Es wurde keine Schwachstelle aktiv ausgenutzt; die tatsächliche Ausnutzbarkeit wurde nicht verifiziert. Die Ergebnisse erlauben daher weder die Behauptung einer erfolgreichen Kompromittierung noch eine Aussage, dass die Systeme vollständig sicher sind.

Dokumentenstatus: erweiterter Zwischenbericht. Noch kein abschließender Pentest-Bericht. Bewertungen beruhen auf den bisher dokumentierten Beobachtungen und den sichtbaren ZAP-Meldungen.